

Identifying Exploited and Likely-to-Be-Exploited Vulnerabilities



Patrick Garrity



Wade Sparks

#VulnCon26

www.first.org/conference/vulncon26/

SPEAKER

Scottsdale, USA • April 13-16, 2026



VulnCheck

CVE

FIRST

VulnCheck Research Team

Coordinated Vulnerability Disclosure

Advisories

Report a Vulnerability

Report a vulnerability to VulnCheck to be responsibly disclosed

[Learn more →](#)

Vulnerability Research

Expanding VulnCheck's KEV: Auditing ShadowServer, New CVE Assignments, and Source Expansion



Patrick Garrity
[in/patrickmgarrity/](#)

In recent weeks, our KEV (Known Exploited Vulnerabilities) feed has seen a notable increase in CVEs. If you've noticed and are wondering what's driving the spike, you're not alone. The short answer: VulnCheck has been hard at work closing the gap on untracked exploitation by auditing publicly available sources and assigning CVEs where none existed. Here's a look behind the scenes at what's been happening.

Exploit Research

Metro4Shell: Exploitation of React Native's Metro Server in the Wild



Jacob Baines
[@Junior_Baines](#)

- ✓ VulnCheck Canaries observed exploitation of **CVE-2025-11953** in late December.
- ✓ Canary telemetry shows **CVE-2025-11953** being used operationally, with consistent payload delivery across multiple dates rather than one-off probing or research activity.
- ✓ Exploitation delivered advanced payloads on Windows systems, demonstrating that Metro4Shell provides a practical initial access mechanism when exposed to the public internet.

Identifying Exploited and Likely-to-Be- Exploited Vulnerabilities



Cyber Resilience Act (CRA)



After the product is placed on the market, the manufacturer is required to notify actively exploited vulnerabilities and severe incidents having an impact on the security of the product that it becomes aware of.

The manufacturer needs to submit to notifications to the Computer Security Incident Response Team (CSIRT) of the Member State in which it has its main establishment and to ENISA, within the following deadlines:

- **24 hours for an early warning notification;**
- **72 hours for the "main" notification;**
- **a final report no later than 14 days after a corrective or mitigating measure is available for actively exploited vulnerabilities;**
- **a final report within one month from the 72h submission for severe incidents.**

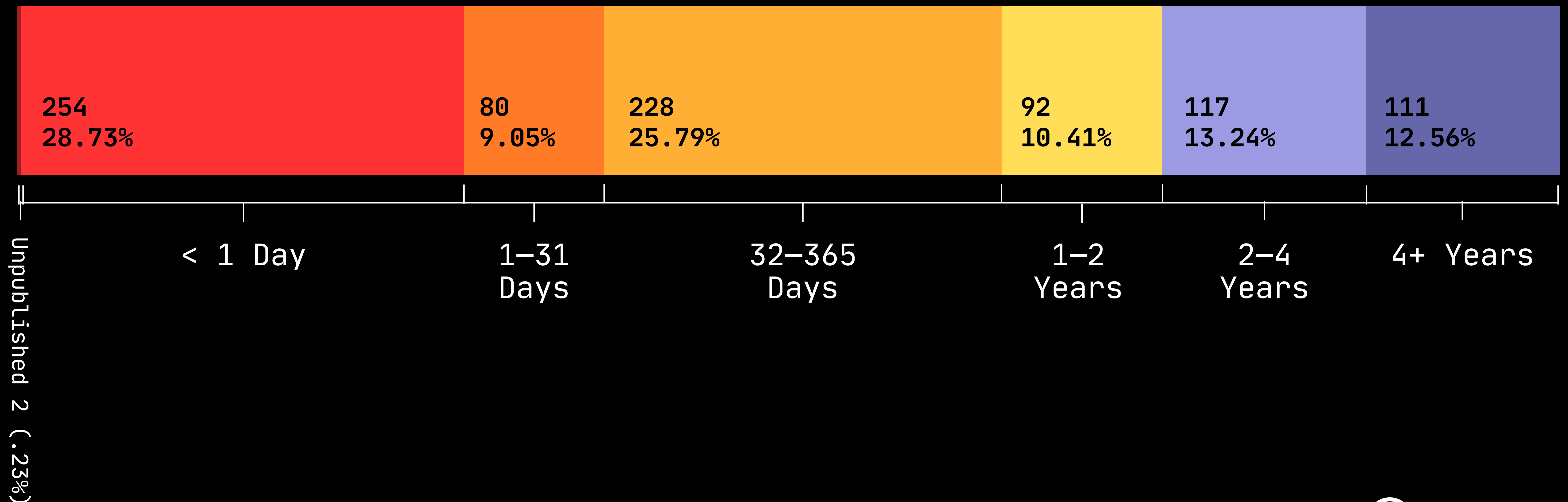
VulnCheck KEV Criteria for This Talk

We include any vulnerability publicly-reported as exploited in the wild or detected by VulnCheck as a KEV...

How Quickly Do Vulnerabilities Get Exploited?

Time From CVE to Exploitation Evidence

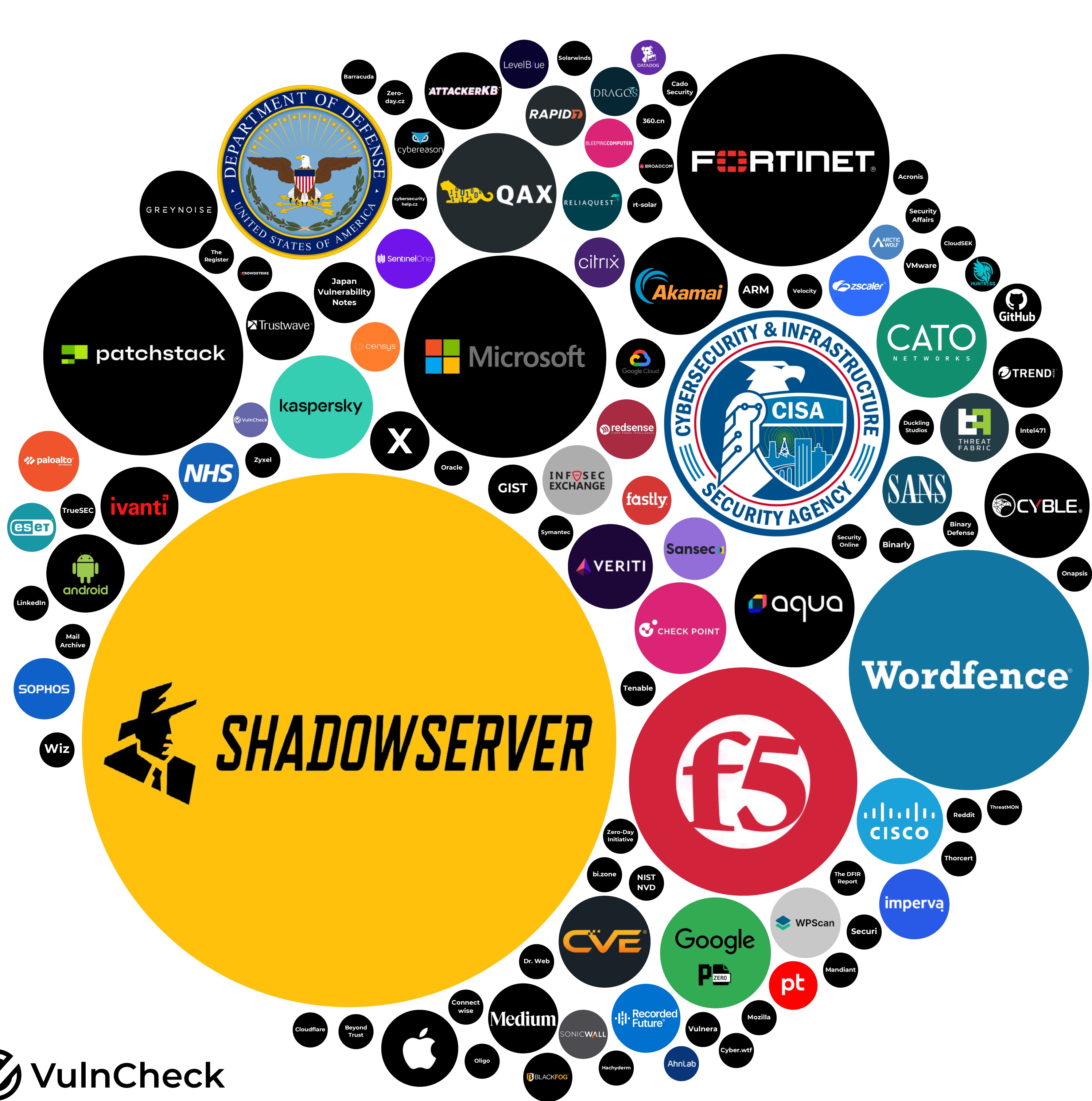
Source: VulnCheck KEV 2025



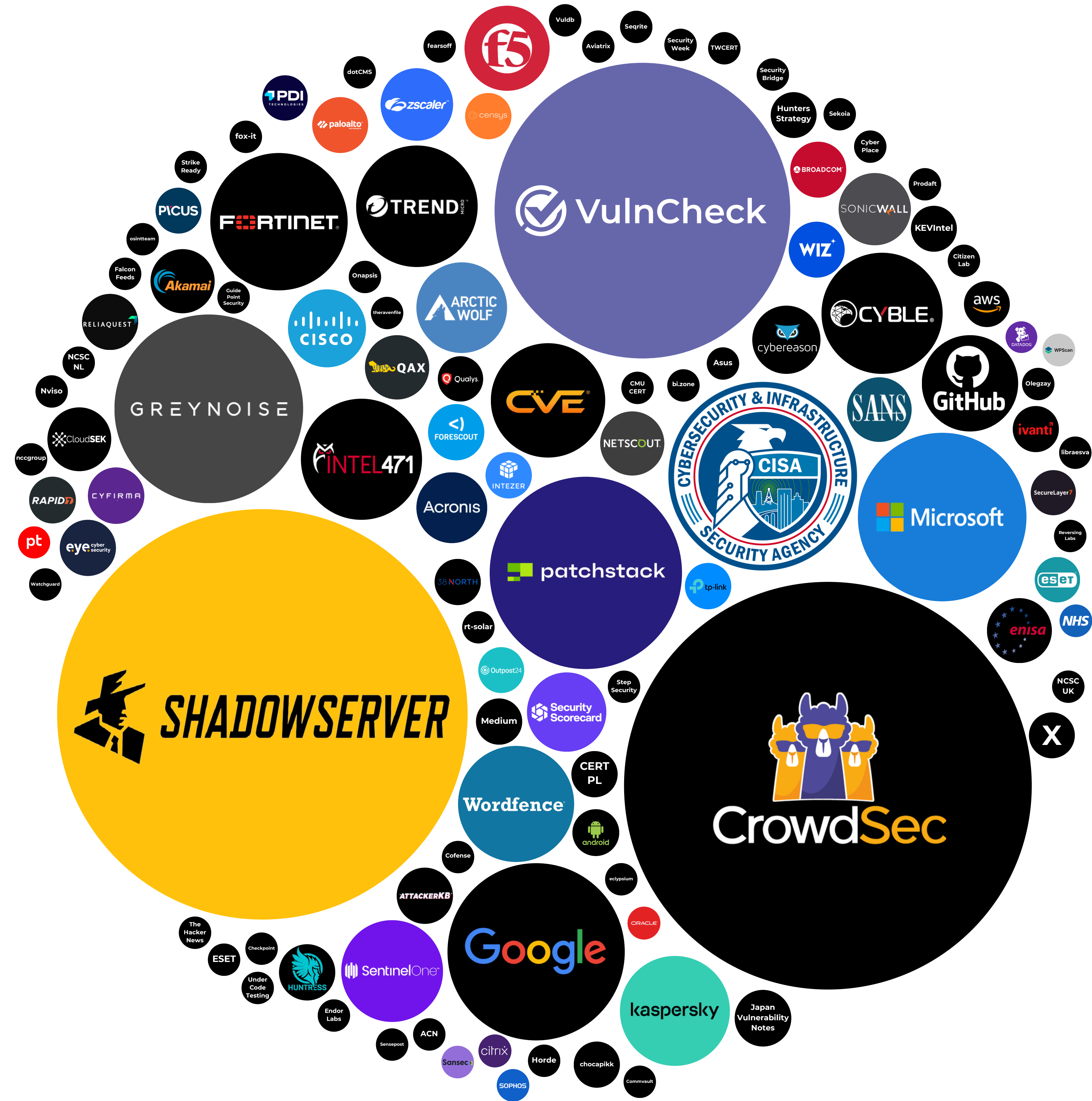
Where Does Exploitation Evidence Come From?

Source: VulnCheck KEV

2024

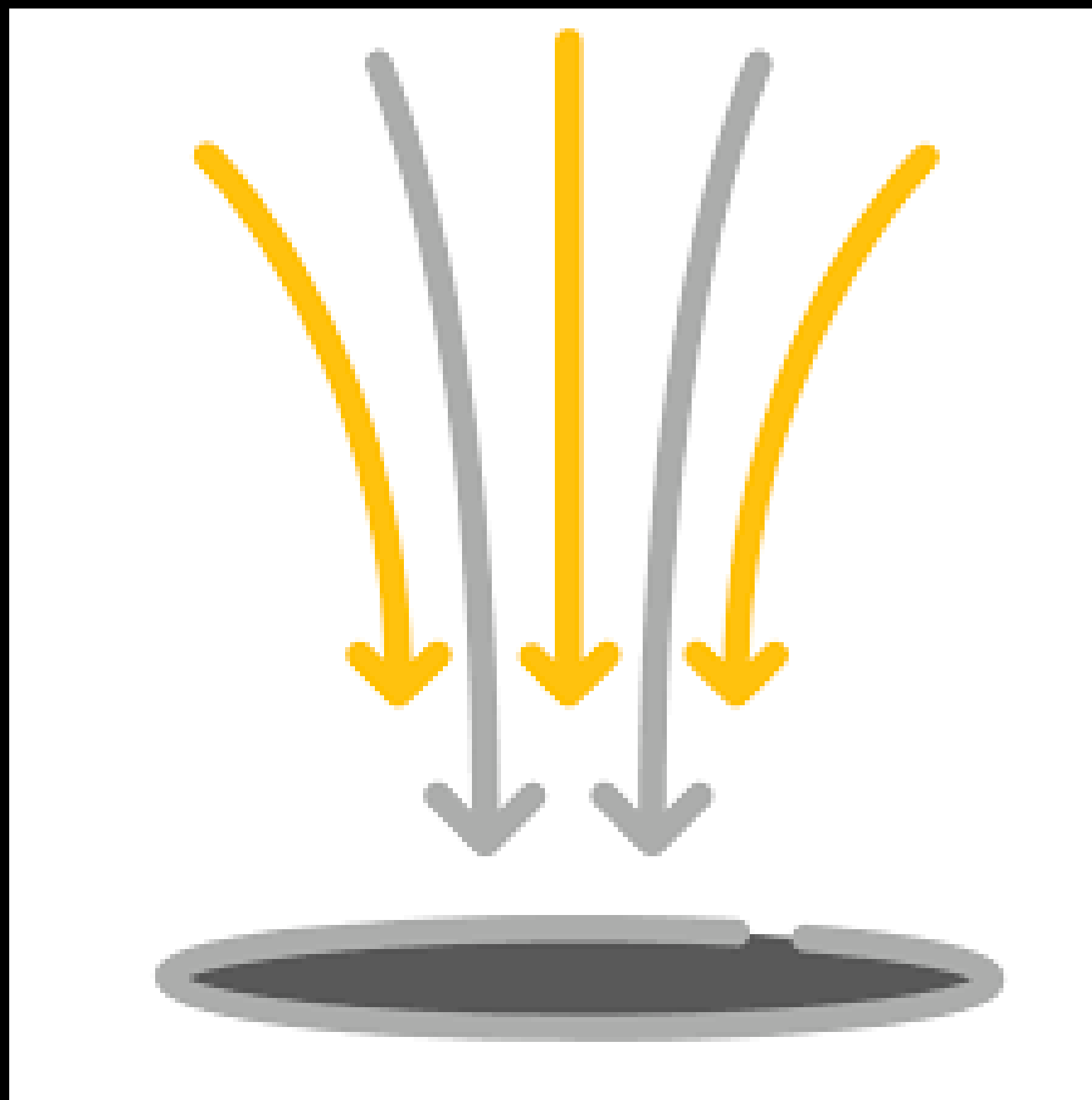


2025



Example 1: Shadowserver

Shadowserver Honey pots & Sinkholes



“We provide free technical assistance to many of the world’s most significant cybercrime disruption operations, quarantining millions of malicious domains using our special purpose DNS registrar, the Registrar of Last Resort (RoLR). We conduct ‘sinkholing’ – the process of disrupting the connections between malware-infected devices and threat actor-controlled servers, and redirecting that traffic safely to our sinkhole servers.”



SHADOWSERVER

Lighting the way to a more secure Internet

Top Exploited Vulnerabilities

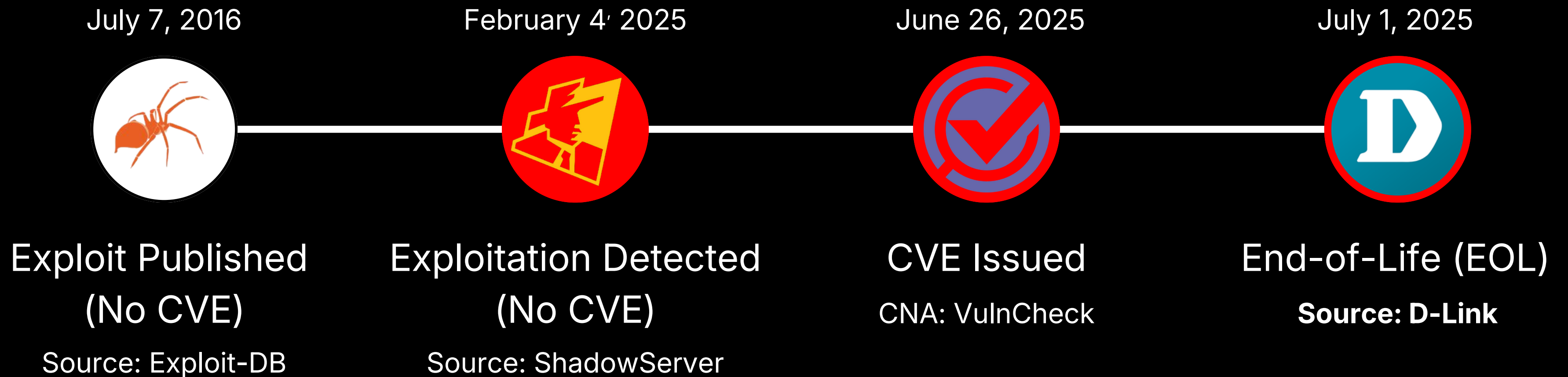
Exploited vulnerabilities - Top

Showing results for 2026-04-08

#	Vulnerability	Vendor	Product	IoT	KEV	Ransomware	1d	7d avg	30d avg	90d
1	CVE-2017-17215	Huawei	Huawei Home Gateway HG532	✓	✗	-	1,243	1,316	1,019	
2	EDB-44760	D-Link	D-Link DSL-2750B	✓	✗	-	403	831	256	
3	CVE-2020-10173	Comtrend	Comtrend VR-3033	✓	✗	-	392	817	263	
4	CVE-2014-8361	Realtek	Realtek SDK	✓	✓	Unknown	342	349	328	
5	CVE-2018-10562	Dasan	Dasan GPON Home Router	✓	✓	Known	335	293	316	
6	CVE-2024-12847	Netgear	Netgear DGN1000	✓	✗	-	311	279	312	
7	CVE-2021-42013	Apache	Apache HTTP Server	✗	✓	Known	280	298	294	
8	CVE-2023-20198	Cisco	Cisco IOS XE	✗	✓	Unknown	277	273	253	
9	CVE-2016-10372	Zyxel	Eir D1000	✓	✗	-	277	268	307	
10	CVE-2017-9841	PHPUnit - Sebastian Bergmann	PHPUnit	✗	✓	Unknown	265	276	249	
11	EDB-41471	MVPower	MVPower DVR	✓	✗	-	188	164	191	
12	CNVD-2018-24942	TopThink	ThinkPHP5	✗	✗	-	178	184	180	
13	CVE-2025-34036	Shenzhen TVT	CCTV-DVR (rebranded by mul...	✓	✗	-	161	143	163	

Exploited Vulnerability Timeline

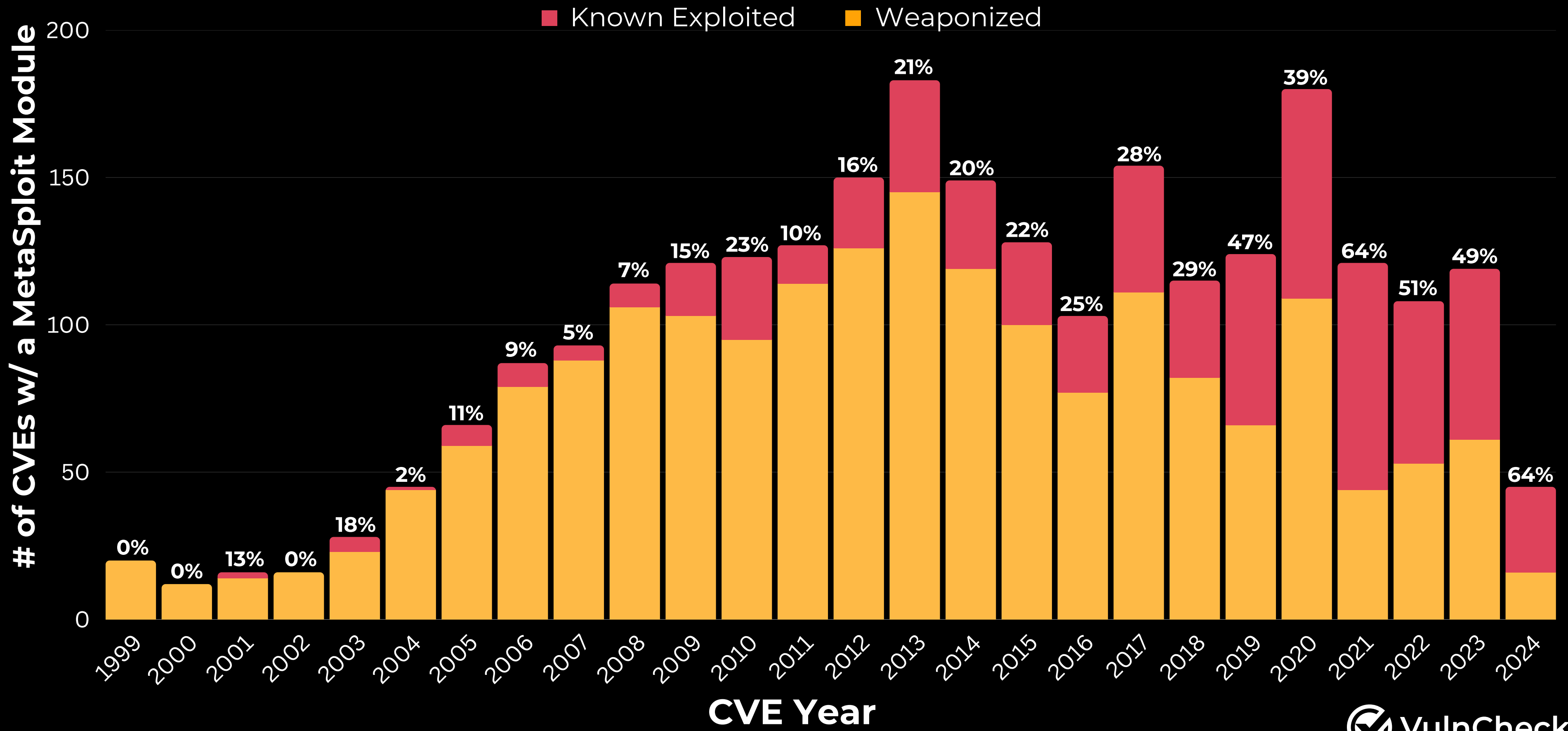
CVE-2025-34048 | D-Link DSL-2750U | Path Traversal



Example 2: Metasploit

Metasploit Modules Mapped to Known Exploited Vulnerabilities

Source: VulnCheck KEV / Metasploit Project



Metasploit in Action

timestamp: 2023-10-10 09:04:09,
chat_id: !BOpqkyiMnBRfCPXwod:matrix.bestflowers247.online,
sender_alias: @username:matrix.bestflowers247.online,
message: `curl https://raw.githubusercontent.com/rapid7/metasploit-omnibus/master/config/templates/metasploit-framework-wrappers/msfupdate.erb
> msfinstall && chmod 755 msfinstall && ./msfinstall`



HD Moore's Law

"Casual Attacker power
grows at the rate of
Metasploit"
- Joshua Corman

Exploited Vulnerability Timeline

CVE-2025-34117 | netis-systems netcore_router_firmware



Example 3: Product Security Advisories

Product Security Advisory

NotePad++

Notepad++ Hijacked by State-Sponsored Hackers

2026-02-02

Following the security disclosure published in the v8.8.9 announcement <https://notepad-plus-plus.org/news/v889-released/>

the investigation has continued in collaboration with external experts and with the full involvement of my (now former) shared hosting provider.

According to the analysis provided by the security experts, the attack involved infrastructure-level compromise that allowed malicious actors to intercept and redirect update traffic destined for notepad-plus-plus.org. The exact technical mechanism remains under investigation, though the compromise occurred at the hosting provider level rather than through vulnerabilities in Notepad++ code itself. Traffic from certain targeted users was selectively redirected to attacker-controlled malicious update manifests.

DIBS Consensus



wsparks-vc on Feb 2

Collaborator Author ...

In the meantime, we have reached out the maintainer to determine CNA engagement and potentially collaborate on CVE assignment.

 1



todb on Feb 2

Contributor ...

Go forth and catalog it.





zmanion on Feb 2

Collaborator ...

Dibs-Agree from the CISA-CG CNA. To be clear, CISA-CG is not assigning. We might want to change the name of this message, the name should clearly indicate that the CNA is *not* assigning (so, something that conveys "not-assigning").

I think this is a fine candidate for DIBS, but also this was public on 2025-12-09, so doesn't fall in the 30 or 14 day urgency/freshness windows we've been discussing. So it might be old enough that the risk of collision is low so an observing CNA could have taken the chance and assigned without invoking DIBS. Also noting that we've all agreed that age alone isn't the only factor in determining urgency/DIBS criteria.

 1



cve-team on Feb 2

Collaborator ...

The MITRE CNA-LR has no plans to assign/publish. (Vulnerability Determination seems fine when relying only on 4.1.1; Vulnerability Determination would be problematic if based on a more general notion that Suppliers are supposed to go beyond https-based downloads - such as Notepad++ choosing to pay hundreds of dollars per year to GlobalSign for a code signing certificate <https://www.globalsign.com/en/code-signing-certificate> for example)

 1

CVE Published

CVE-2025-15556

CNA: VulnCheck

Published: 2026-02-03 **Updated:** 2026-03-05
Title: Notepad++ < 8.8.9 WinGUp Updater Lacks Update Integrity Verification
Tags: known-exploited-vulnerability

Description

Notepad++ versions prior to 8.8.9, when using the WinGUp updater, contain an update integrity verification vulnerability where downloaded update metadata and installers are not cryptographically verified. An attacker able to intercept or redirect update traffic can cause the updater to download and execute an attacker-controlled installer, resulting in arbitrary code execution with the privileges of the user.

CWE 1 Total
[Learn more](#)

- [CWE-494: CWE-494 Download of Code Without Integrity Check](#)

CVSS 1 Total
[Learn more](#)

Score	Severity	Version	Vector String
7.7	HIGH	4.0	CVSS:4.0/AV:N/AC:H/AT:N/PR:N/UI:P/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N

Added to CISA KEV

CISA Adds Four Known Exploited Vulnerabilities to Catalog

Release Date: February 12, 2026



CISA has added four new vulnerabilities to its [Known Exploited Vulnerabilities \(KEV\) Catalog](#), based on evidence of active exploitation.

- **CVE-2024-43468** ⓘ Microsoft Configuration Manager SQL Injection Vulnerability
- **CVE-2025-15556** ⓘ Notepad++ Download of Code Without Integrity Check Vulnerability
- **CVE-2025-40536** ⓘ SolarWinds Web Help Desk Security Control Bypass Vulnerability
- **CVE-2026-20700** ⓘ Apple Multiple Buffer Overflow Vulnerability

Example 4: Security Researchers

Security Researchers

Versa Concerto - ProjectDiscovery - CVE-2025-34026

CVE-2025-34026

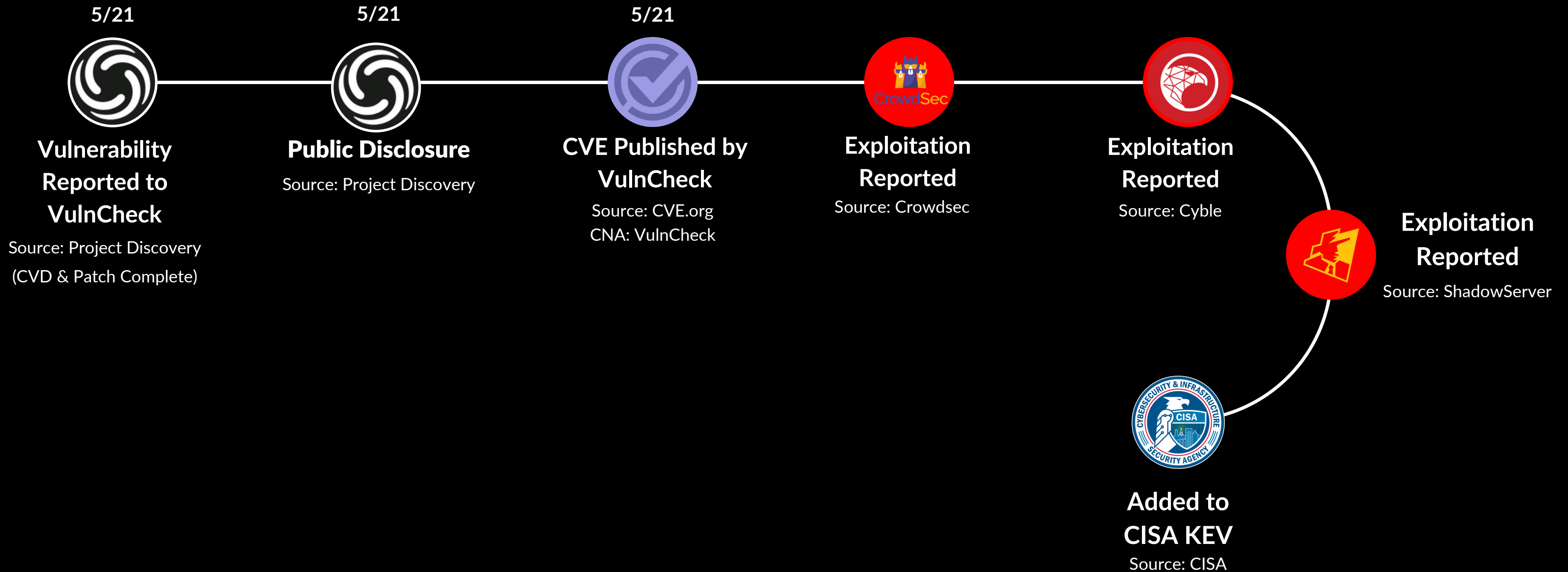
Versa Concerto Actuator Endpoint - Authentication Bypa...

iamnooooob, rootxharsh, parthmalhotra, pdresearch

 ProjectDiscovery

CVE / Exploitation Timeline

Versa Concerto - ProjectDiscovery - CVE-2025-34026



Example 5: VulnCheck Research

VulnCheck Research

SmarterMail ConnetToHub - Unauthenticated RCE

Street Smarts: SmarterMail ConnetToHub Unauthenticated RCE (CVE-2026-24423)



Cale Black
hosakacorp.net

VulnCheck's security research team identified an unauthenticated remote code execution vulnerability in SmarterTools SmarterMail, which we disclosed to the software supplier in accordance with VulnCheck's vulnerability disclosure policy. The vulnerability, which VulnCheck has assigned **CVE-2026-24423**, arises from the ability to execute arbitrary commands in the mounting logic and was discovered independently by at least four different researchers:

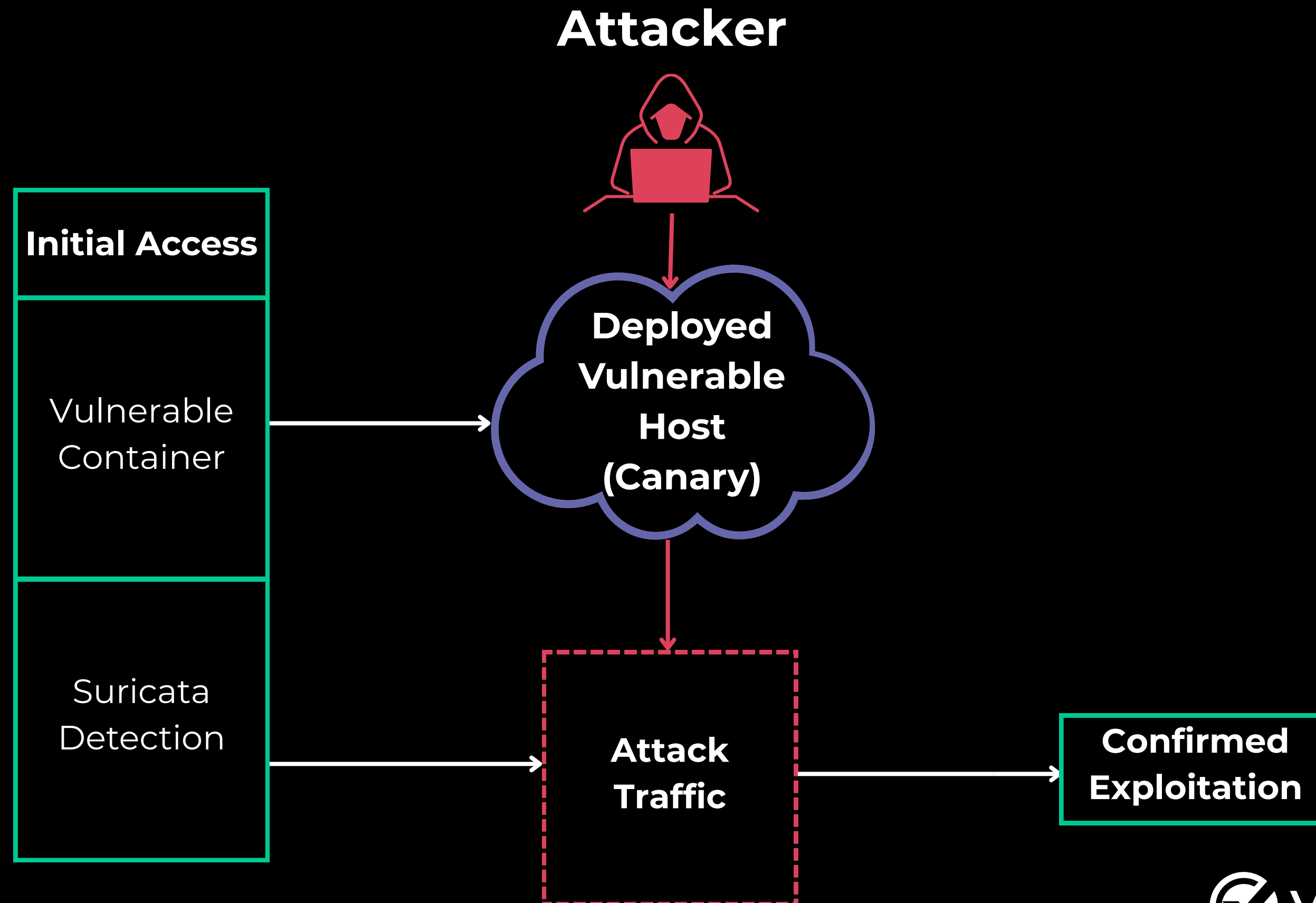
- Sina Kheirkhah & Piotr Bazydlo of watchTower
- Markus Wulftange of CODE WHITE GmbH

Researcher Collision

SmarterMail ConnetToHub - Unauthenticated RCE



VulnCheck Canaries



Exploitation Timeline

SmarterMail - CVE-2026-24423

1/23



CVE Published

Source: VulnCheck

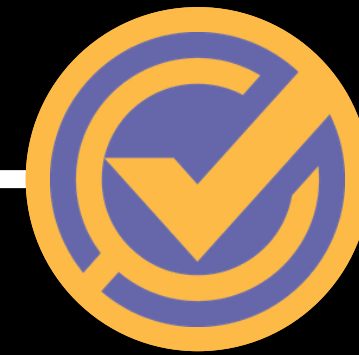
1/26



**Detections
Published**

Source: VulnCheck

1/28



Canary Detection
Source: VulnCheck Canaries

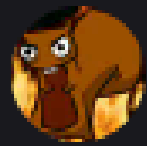


CISA KEV
Source: CISA KEV

Example 6: Community Forums

Community Forums

EVC > FreeBSD Forum > Xenforo



jericho (Vuln Historian)

 Yesterday at 5:34 PM

<https://forums.freebsd.org/threads/forum-outage.102193/> they do
FreeBSD asking them to confirm

The FreeBSD Forums

Forum Outage

Hi guys, sorry that the FreeBSD Forums were offline for a couple of hours.

We were hit by an exploit against a slightly outdated XenForo version that we were still running.

Feb 5, 2026 · Replies: 3

XenForo 2.3.9 Released

Today we are releasing XenForo 2.3.9 to address some potential security vulnerabilities that w
bug fixes we previously said would make it to 2.3.9 have now been delayed until 2.3.10.

It is now available for all licensed customers to download. We strongly recommend that all cu
benefit from increased stability.

The issues identified are as follows:

- Prevention of a possible stored XSS (cross-site scripting) exploit related to BB code rendering (thank you to Antisocial)
- Prevention of a possible XSS exploit related to lightbox usage in posts (thank you UwU)
- Prevention of a possible RCE (remote code execution) exploit via authenticated, but malicious, admin users (thank you UwU)

If you are a XenForo Cloud customer, fixes for these issues have been rolled out automatically, and no further action is required to address them.

We recommend doing a full upgrade to resolve the issue, but a patch can be applied manually. See below for further details.

CVE-2026-35056

PUBLISHED

[View JSON](#) | [User](#)

Collap

Required CVE Record Information

CNA: VulnCheck

Published: 2026-04-01 Updated: 2026-04-01

Title: XenForo Remote Code Execution via Authenticated Admin

Description

XenForo before 2.3.9 and before 2.2.18 allows remote code execution (RCE) by authenticated, but malicious, admin users. An attacker with admin pan
access can execute arbitrary code on the server.

CWE 1 Total

[Learn more](#)

- [CWE-94: CWE-94: Improper Control of Generation of Code \('Code Injection'\)](#)

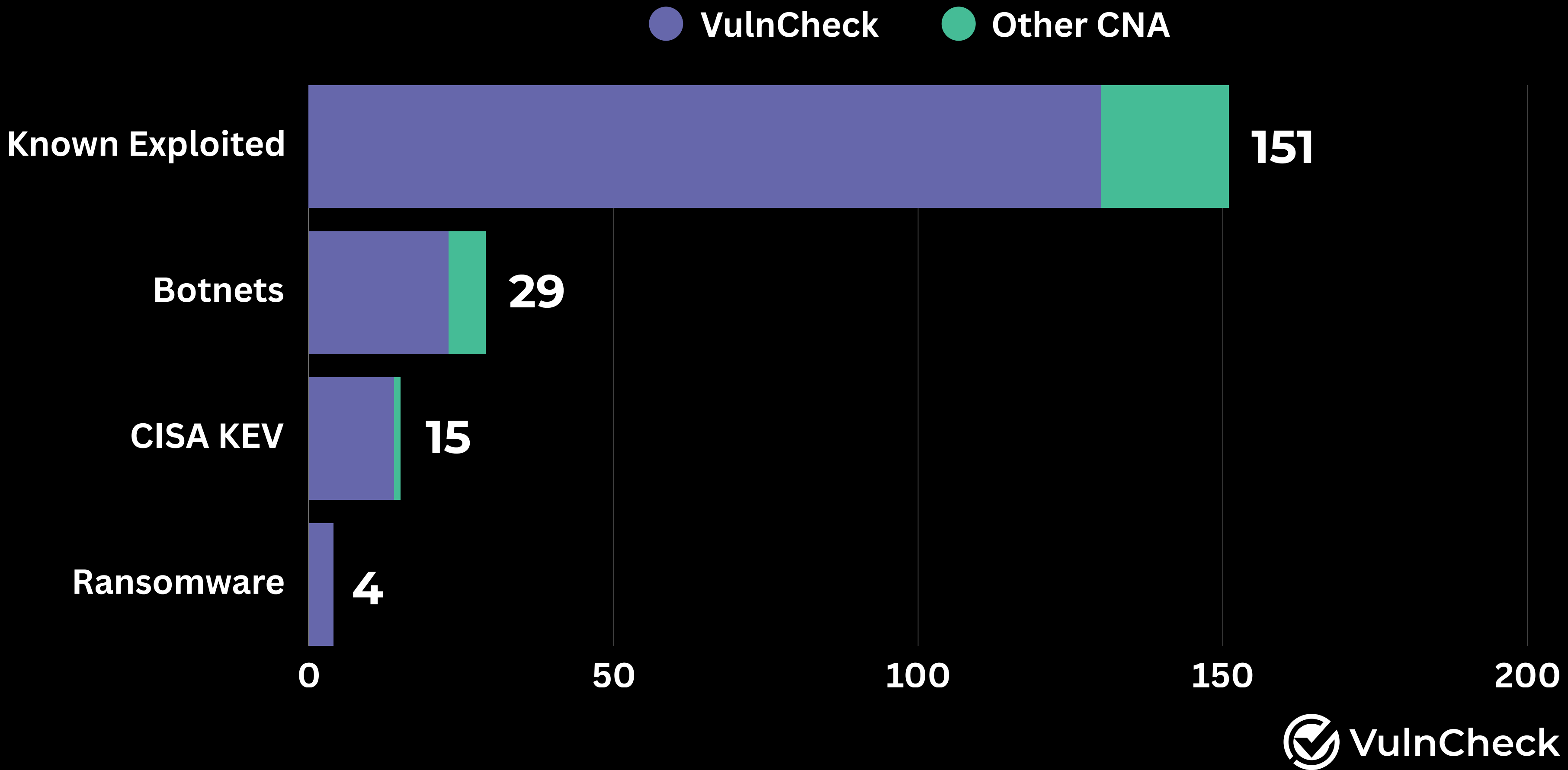
CVSS 2 Total

[Learn more](#)

Score	Severity	Version	Vector String
-------	----------	---------	---------------

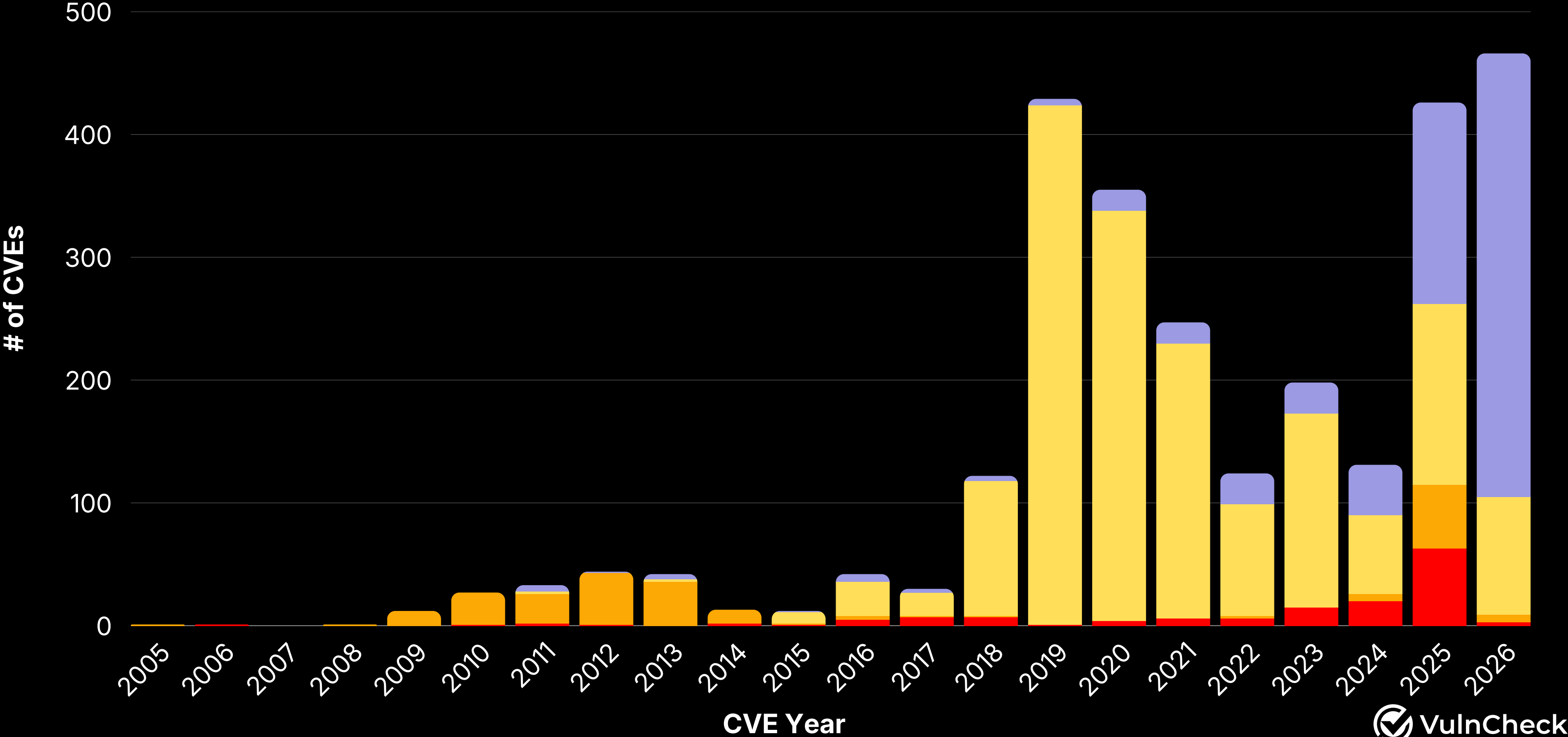
Let's Look at the Results...

CVEs (Coordinated / Published) by VulnCheck



VulnCheck CNA Published CVEs

● KEV ● Weaponized Exploit ● POC Exploit ● CVE Only



**Thank
You!**

Appendix

Exploitation Happens at Anytime

